CommerceFlow — Sprint 1A Design Audit v1.0

DRAFT FOR ENGINEERING REVIEW

Confirmed design baseline

• Session authentication using Spring Security and Spring Session JDBC; CSRF protection on state-changing requests.

• Ten business tables; session and idempotency persistence are additional infrastructure tables.

• USD-only amounts represented as decimal strings in JSON; product-level stock and atomic conditional updates.

• Mock payment with no real card data; customer cart requires login.

Findings requiring resolution before implementation

• D-01 [HIGH] Checkout idempotency: specify key scope (customer + key), canonical request fingerprint, uniqueness, concurrent IN_PROGRESS handling, TTL, crash recovery, and response replay.

• D-02 [HIGH] CSRF: specify SPA token bootstrap, login/logout token rotation, cookies, CORS and same-site deployment policy.

• D-03 [HIGH] Order cancellation: specify permitted actors, transitions, restock exactly once, and concurrency behavior.

• D-04 [MEDIUM] Product availability: specify behavior for inactive products in public catalog and historical order references.

• D-05 [MEDIUM] API coverage: FR-07 search/filter must have explicit query parameters and validation; FR-17/18 require consistent validation and Problem Details schemas.

• D-06 [MEDIUM] Database: physical DDL requires foreign-key deletion policies, indexes, case-insensitive email uniqueness and order snapshot constraints.

• D-07 [MEDIUM] UML: diagrams remain editable high-level drafts and require formal relationship/multiplicity and PDF visual review.

Proposed checkout policy for approval

• An idempotency key is scoped to the authenticated customer and retained for 24 hours after completion (proposed, not approved).

• Same key + same payload: return prior completed result; same key + different payload: HTTP 409.

• Concurrent request with an in-progress matching key: HTTP 409 with a retry indication, rather than creating another order.

• A successful mock payment precedes the database write transaction; on mock failure no order or inventory changes are committed.

• Only CONFIRMED orders may be cancelled; cancellation restores reserved inventory exactly once inside a transaction.

API inventory

• OpenAPI 3.1 YAML contains 19 paths and 21 HTTP operations; server base path is /api/v1.

• OpenAPI security uses a cookie-based apiKey placeholder named SESSION; actual cookie policy requires configuration and verification.

• No application code, migration, CI change or GitHub commit is included in this audit.